

Incident Analysis

Timeline Reconstruction (UTC Normalized)

The logs were in the PST Time Zone as can be seen in the security_test_schedule.pdf. Logs below are UTC normalized and chronologically sorted. Activity from scheduled Automated Test IP Ranges (192.168.1.100 and 10.0.0.0/24) are filtered, isolating only external attacks.

External Attacks Started At **2024-10-15 14:45:10 UTC**. 5 to 10 days earlier than scheduled date.

```
2024-10-15 06:45:10,1523,/api/v1/login,POST,,200,267,203.0.113.45,Acme-Mobile-Android/3.2.0,
2024-10-15 06:46:30,1523,/api/v1/portfolio/1523,GET,1523,200,156,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:15,1523,/api/v1/portfolio/1524,GET,1524,200,143,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:18,1523,/api/v1/portfolio/1525,GET,1525,200,138,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:21,1523,/api/v1/portfolio/1526,GET,1526,200,147,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:24,1523,/api/v1/portfolio/1527,GET,1527,200,141,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:27,1523,/api/v1/portfolio/1528,GET,1528,200,139,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:30,1523,/api/v1/portfolio/1529,GET,1529,200,144,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:33,1523,/api/v1/portfolio/1530,GET,1530,200,142,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:36,1523,/api/v1/portfolio/1531,GET,1531,200,148,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:39,1523,/api/v1/portfolio/1532,GET,1532,200,145,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:42,1523,/api/v1/portfolio/1533,GET,1533,200,140,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:45,1523,/api/v1/portfolio/1534,GET,1534,200,146,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:48,1523,/api/v1/portfolio/1535,GET,1535,200,143,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:51,1523,/api/v1/portfolio/1536,GET,1536,200,149,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:54,1523,/api/v1/portfolio/1537,GET,1537,200,141,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:57,1523,/api/v1/portfolio/1538,GET,1538,200,147,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
```

Logs from **api_logs.csv** shows that multiple requests with the same stolen token to different ID's returned Success Response (200).

WAF detected at **14:47:30 UTC** API attacks but did not block as configuration was set to DETECT mode instead of BLOCK mode.

```
2024-10-15 06:47:30,942100,MEDIUM,DETECT,203.0.113.45,/api/v1/portfolio/1529,Rapid Sequential Access,no
2024-10-15 06:47:45,942100,MEDIUM,DETECT,203.0.113.45,/api/v1/portfolio/1534,Rapid Sequential Access,no
2024-10-15 06:47:57,942100,HIGH,DETECT,203.0.113.45,/api/v1/portfolio/1538,Possible Account Enumeration,no
```

After the API Security Test Attack, E-Mail Phishing Attack started at **17:00:23 UTC**. Shown via screenshot from **email_logs.csv** below, half of the users (3/6) clicked the phishing link.

```
2024-10-15 09:00:23,security@acme-finance.com,user1@acme.com,URGENT: Verify Your Account - Action Required,yes,203.0.113.45,
2024-10-15 09:00:25,security@acme-finance.com,user2@acme.com,URGENT: Verify Your Account - Action Required,no,,
2024-10-15 09:00:27,security@acme-finance.com,user3@acme.com,URGENT: Verify Your Account - Action Required,yes,203.0.113.45,
2024-10-15 09:00:29,security@acme-finance.com,user4@acme.com,URGENT: Verify Your Account - Action Required,no,,
2024-10-15 09:00:31,security@acme-finance.com,user5@acme.com,URGENT: Verify Your Account - Action Required,yes,203.0.113.45,
2024-10-15 09:00:33,security@acme-finance.com,user6@acme.com,URGENT: Verify Your Account - Action Required,no,,
```

As the phishing link clicked WAF detected “Suspicious Link Pattern” but did not BLOCK again. Showing that social engineering was successful.

```
2024-10-15 09:00:23,950107,HIGH,DETECT,203.0.113.45,/verify-account.php,Suspicious Link Pattern,no
```

After the social engineering, the attacker focused on Web Application at **17:18:30 UTC**. As shown in the screenshot from **web_logs.csv** and **waf_logs.csv** attacker used the “/dashboard/search” endpoint to execute SQL queries. WAF blocked the basic-known SQL injection parameters but only detected “Suspicious SQL Pattern” and did not BLOCK. Therefore the request with “/*!5000OR*/ 1=1--” returned status code 200. Seconds after the successful SQLi, the attacker requested the “/dashboard/export” endpoint and successfully exported 892341 byte sized response.

```
2024-10-15 09:18:30,1523,/login,,200,3421,203.0.113.45,Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0
2024-10-15 09:19:15,1523,/dashboard,,200,8934,203.0.113.45,Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0
2024-10-15 09:20:30,1523,/dashboard/search,ticker=AAPL' OR 1=1--,403,567,203.0.113.45,Mozilla/5.0 (Windows NT 10.0; Win64;
2024-10-15 09:21:15,1523,/dashboard/search,ticker=AAPL'; DROP TABLE users--,403,567,203.0.113.45,Mozilla/5.0 (Windows NT 10
2024-10-15 09:22:00,1523,/dashboard/search,ticker=AAPL' UNION SELECT * FROM users--,403,567,203.0.113.45,Mozilla/5.0 (Windo
2024-10-15 09:23:45,1523,/dashboard/search,ticker=AAPL' /*!5000OR*/ 1=1--,200,156789,203.0.113.45,Mozilla/5.0 (Windows NT
2024-10-15 09:24:10,1523,/dashboard/export,format=csv,200,892341,203.0.113.45,Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chr
2024-10-15 09:30:00,1523,/dashboard/home,200,,200,8934,203.0.113.45,Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0

2024-10-15 09:20:30,981173,HIGH,DETECT,203.0.113.45,/dashboard/search,SQL Injection Attempt - OR 1=1,yes
2024-10-15 09:21:15,981318,CRITICAL,BLOCK,203.0.113.45,/dashboard/search,SQL Injection - DROP TABLE,yes
2024-10-15 09:22:00,981257,HIGH,BLOCK,203.0.113.45,/dashboard/search,SQL Injection - UNION SELECT,yes
2024-10-15 09:23:45,981001,MEDIUM,DETECT,203.0.113.45,/dashboard/search,Suspicious SQL Pattern,no
```

Attack Vector Identification

1. **Broken Access Control(API):** Accessing multiple account information using a single token.
2. **E-Mail Phishing:** The attackers aim was to be able to direct traffic to the “verify_account.php” and succeeded with social engineering.
3. **SQL Injection:** Exploited search endpoint and executed SQL queries.

Attack Classification

1. **OWASP A01-2025 - Broken Access Control:** Accessing multiple accounts with only one token. Screenshot from **api_logs.csv** shows 200 response codes to different accounts with one token.

```
2024-10-15 06:46:30,1523,/api/v1/portfolio/1523,GET,1523,200,156,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:15,1523,/api/v1/portfolio/1524,GET,1524,200,143,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:18,1523,/api/v1/portfolio/1525,GET,1525,200,138,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:21,1523,/api/v1/portfolio/1526,GET,1526,200,147,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:24,1523,/api/v1/portfolio/1527,GET,1527,200,141,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:27,1523,/api/v1/portfolio/1528,GET,1528,200,139,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:30,1523,/api/v1/portfolio/1529,GET,1529,200,144,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:33,1523,/api/v1/portfolio/1530,GET,1530,200,142,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:36,1523,/api/v1/portfolio/1531,GET,1531,200,148,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:39,1523,/api/v1/portfolio/1532,GET,1532,200,145,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:42,1523,/api/v1/portfolio/1533,GET,1533,200,140,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:45,1523,/api/v1/portfolio/1534,GET,1534,200,146,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:48,1523,/api/v1/portfolio/1535,GET,1535,200,143,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:51,1523,/api/v1/portfolio/1536,GET,1536,200,149,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:54,1523,/api/v1/portfolio/1537,GET,1537,200,141,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
2024-10-15 06:47:57,1523,/api/v1/portfolio/1538,GET,1538,200,147,203.0.113.45,Acme-Mobile-Android/3.2.0,jwt_token_1523_stolen
```

2. **MITRE ATT&CK T1566.002:** Phishing via Malicious link. Encouraging users to click the malicious link. In our case 3 different users clicked the link.

```
2024-10-15 09:00:23,security@acme-finance.com,user1@acme.com,URGENT: Verify Your Account - Action Required,yes,203.0.113.45,
2024-10-15 09:00:25,security@acme-finance.com,user2@acme.com,URGENT: Verify Your Account - Action Required,no,,
2024-10-15 09:00:27,security@acme-finance.com,user3@acme.com,URGENT: Verify Your Account - Action Required,yes,203.0.113.45,
2024-10-15 09:00:29,security@acme-finance.com,user4@acme.com,URGENT: Verify Your Account - Action Required,no,,
2024-10-15 09:00:31,security@acme-finance.com,user5@acme.com,URGENT: Verify Your Account - Action Required,yes,203.0.113.45,
2024-10-15 09:00:33,security@acme-finance.com,user6@acme.com,URGENT: Verify Your Account - Action Required,no,,
```

3. **OWASP A05-2025 - Injection:** Specifically SQL Injection. Exploiting the “search” endpoint with SQL query inputs and executing. In our case, WAF bypass with a special SQL query returned status code 200 as successful injection.

```
2024-10-15 09:20:30,1523,/dashboard/search,ticker=AAPL' OR 1=1--,403,567,203.0.113.45,Mozilla/5.0 (Win
2024-10-15 09:21:15,1523,/dashboard/search,ticker=AAPL'; DROP TABLE users--,403,567,203.0.113.45,Mozil
2024-10-15 09:22:00,1523,/dashboard/search,ticker=AAPL' UNION SELECT * FROM users--,403,567,203.0.113.45,Mozil
2024-10-15 09:23:45,1523,/dashboard/search,ticker=AAPL' /*!500000R*/ 1=1--,200,156789,203.0.113.45,Mozil
```

4. **MITRE ATT&CK 1567:** Exfiltration Over Web Service. In our case the attacker exported 892341 byte sized data via /dashboard/export endpoint.

```
2024-10-15 09:24:10,1523,/dashboard/export,format=csv,200,892341,203.0.113.45,
```

Root Cause Analysis

Broken Access Control(API): The root cause of the issue is not checking the token’s ownership.

SQL Injection(Web): Root cause of the issue is not blocking the Suspicious SQL Pattern on WAF and only using DETECT mode. Also not using Parameterized Queries at the Database Level.

E-Mail Phishing: Root cause of the successful attack is the E-mail gateway allowing the malicious link attached fake mails. And the users did not notice the wrong domain (acme-finance.com).

Impact Assessment

Confidentiality Breach: Attackers managed to access multiple user portfolios and managed to export 892341 byte sized csv file.

Architecture Review

I am weak in this area due to no experience in the Cyber Security field. But i would love to improve myself.

Current Architecture Weaknesses

Improved Security Architecture Diagram

Recommended Security Controls

Using parameterized queries for the database interaction as this step would secure the database from SQLi attacks.

Reinforcing the WAF Rules from basic and at least adding OWASP Top10 list.

Changing the WAF Configurations mentioned before from DETECT to BLOCK.

Educate the users for phishing mails.

Reinforce the e-mail gateway and block lookalike mails.

Improve API Authentication for user-token ownership.

Defence-in-Depth Strategy

Edge: WAF must be configured to BLOCK mode instead of DETECT mode and implement more than Basic Rules. E-mail gateway must be reinforced for lookalike domains.

Application: API must have user-token ownership checks.

Database: Using parameterized queries for the database is crucial for the SQLi attacks.

Human: Mandatory education towards phishing needs to be given to users as click rate on the malicious link was relatively high(%50).

Response & Remediation

Immediate Actions (0-24 Hours)

1. Change WAF Rules from DETECT to BLOCK.
2. Immediately block the IP Address as the attack was 5 to 10 days earlier then scheduled timeline.
3. Invalidate the stolen JWT token (jwt_token_1523_stolen).
4. Mandatory password reset for users who clicked the link(user1,user3,user5).

Short-term Fixes (1-2 weeks)

1. Fix SQLi with parameterized queries.
2. Update API Authentication Policy to ensure user-token ownership.
3. Update the WAF ruleset to include OWASP Top 10 list.
4. Improve e-mail gateway for lookalike domains and malicious links.

Long-term Improvements (1-3 Months)

Probably improvements on the architectural area but as i said i am weak on that field.

Compliance Considerations

Breach Notification: Multiple user portfolios are breached via API authentication and 892341 bytes sized data is exported. Must be reported within 72 hours.